

W3Link

نقشه راه محصول و ارزیابی فنی

ویژگی‌های ناقص، برنامه توسعه آینده و بررسی امنیتی

می ۲۰۲۶

۱. بیانیه چشم‌انداز

W3Link به عنوان دروازه‌ای برای تعامل انسان‌ها با عامل‌های هوش مصنوعی طراحی شده است. پنجره‌ای شبیه پیام‌رسان‌های روزمره، اما با هدف متفاوت: کمک به افراد برای ارتباط با کارمندان انسانی و غیرانسانی.

W3Link سه نقش همزمان ایفا می‌کند:

1. **پیام‌رسان سازمانی** — ارتباطات خصوصی و امن
2. **ابزار کنترل پروژه مبتنی بر هوش مصنوعی** — مدیریت وظایف، پروژه‌ها و جریان‌های کاری از طریق هوش مصنوعی
3. **پنجره به بازار عامل‌های هوش مصنوعی** — کشف، استخدام و مدیریت عامل‌های هوش مصنوعی

۲. وضعیت فعلی ویژگی‌ها

جدول زیر وضعیت فعلی پیاده‌سازی ویژگی‌ها در پلتفرم‌های وب و موبایل را نشان می‌دهد، همراه با اولویت توسعه برای ویژگی‌های ناتمام.

اولویت	موبایل	وب	ویژگی	دسته
-	Done	Done	پیام‌رسانی پایه	پیام‌رسانی
High	Partial	Done	تماس صوتی/تصویری	پیام‌رسانی
Critical	Not Started	Not Started	رمزنگاری سرتاسری	پیام‌رسانی
High	Not Started	Not Started	پاسخ‌های رشته‌ای	پیام‌رسانی
Medium	Not Started	Not Started	تاریخچه ویرایش پیام	پیام‌رسانی
Medium	Not Started	Not Started	قالب‌بندی غنی Markdown	پیام‌رسانی
High	Not Started	Not Started	جستجوی سراسری پیام	پیام‌رسانی
High	Not Started	Not Started	کانال‌ها عمومی/خصوصی	پیام‌رسانی
-	Done	Done	منشی Linda AI	هوش مصنوعی
-	Done	Done	بازار عامل‌ها	هوش مصنوعی
-	Done	Done	ترجمه TransGuy	هوش مصنوعی
Medium	Not Started	Done	جستجوی وب Linda	هوش مصنوعی
High	Not Started	Not Started	عامل خلاصه‌ساز جلسه	هوش مصنوعی
Medium	Not Started	Not Started	عامل بررسی کد	هوش مصنوعی
Medium	Not Started	Not Started	عامل آنبوردینگ	هوش

مصنوعی				
هوش مصنوعی	هماهنگی عامل به عامل	Not Started	Not Started	Low
مدیریت	مدیریت وظایف	Done	Partial	Medium
مدیریت	بوردهای پروژه	Done	Partial	Medium
امنیت	لاگ‌های حسابرسی	Not Started	N/A	Critical
امنیت	مجوزهای دانه‌ای	Not Started	N/A	High
امنیت	حریم خصوصی رسید خوانده شده	Not Started	Not Started	Medium
پلتفرم	کنترل اعلان‌ها	Not Started	Not Started	High
پلتفرم	ویزارد سازمان	Not Started	Not Started	Medium
پلتفرم	پشتیبانی دامنه سفارشی	Not Started	Not Started	Low

۳. نقشه راه ویژگی‌های پیام‌رسان

۳.۱ رمزنگاری سرتاسری (E2EE) — بحرانی

رمزنگاری سرتاسری بالاترین اولویت امنیتی است. تمام محتوای پیام‌ها باید قبل از ارسال در سمت کلاینت رمزنگاری شوند.

- پیاده‌سازی Signal Protocol یا پروتکل رمزنگاری اثبات‌شده مشابه
- مکانیزم تبادل کلید برای ایجاد جلسات امن
- ذخیره‌سازی رمزنگاری‌شده رسانه برای فایل‌ها، تصاویر و پیام‌های صوتی
- چرخش کلید و مدیریت دستگاه برای پشتیبانی چند دستگاهی
- پیشنهاد: libsignal-protocol-javascript به عنوان پیاده‌سازی مرجع

۳.۲ پاسخ‌های رشته‌ای

- زنجیره‌های پاسخ در مکالمات برای بحث‌های سازمان‌یافته
- اعلان‌های رشته‌ای جداگانه از اعلان‌های چت اصلی
- نمایش خلاصه رشته در نمای چت اصلی

۳.۳ کانال‌ها (عمومی و خصوصی)

- کانال‌های به سبک Slack با موضوع و توضیحات
- مجوزها و نقش‌های کانال (مدیر، عضو، فقط خواندنی)
- جستجو و کشف کانال در سازمان
- کانال‌های فقط اعلان برای پخش سراسری شرکت

۳.۴ جستجوی سراسری پیام

- جستجوی متن کامل در تمام مکالمات و کانال‌ها
- فیلتر بر اساس تاریخ، فرستنده، نوع پیام (متن، فایل، رسانه)
- برجسته‌سازی نتایج جستجو با پیش‌نمایش متن
- پیشنهاد: PostgreSQL full-text search یا Elasticsearch برای مقیاس‌پذیری

۳.۵ قالب‌بندی غنی پیام

- پشتیبانی از Markdown (درشت، مورب، بلوک‌های کد، لیست‌ها)
- برجسته‌سازی سینتکس برای قطعات کد
- پیش‌نمایش لینک‌ها با کارتهای متادیتا (Open Graph)

۳.۶ کنترل اعلان‌ها

- تنظیمات بی‌صدا و اعلان به ازای هر مکالمه

- حالت مزاحم نشوید با دسترسی زمان بندی شده
- زمان بندی اعلان ها (گزینه فقط ساعات کاری)

۴. نقشه راه بازار عامل‌های هوش مصنوعی

۴.۱ عامل‌های جدید برای توسعه

- خلاصه‌ساز جلسه: ضبط و خلاصه‌سازی جلسات، استخراج اقدامات لازم
- بررسی کد: بررسی تغییرات کد، پیشنهاد بهبودها، اعمال استانداردها
- آنبوردینگ: راهنمایی کارمندان جدید در راه‌اندازی سازمان و سیاست‌ها
- دستیار HR: مدیریت درخواست مرخصی، سوالات سیاست‌ها، مستندات کارمندان
- دستیار فروش: پیگیری سرخ‌ها، تولید گزارش، مدیریت خط لوله فروش
- پشتیبانی مشتری: مدیریت تیکت‌های پشتیبانی، پاسخ‌های FAQ، ارجاع

۴.۲ هماهنگی عامل به عامل

- عامل‌هایی که می‌توانند وظایف را به عامل‌های دیگر واگذار کنند
- زنجیره‌های جریان کاری (مثلاً Linda وظیفه ایجاد می‌کند، عامل بررسی کد بررسی می‌کند، خلاصه‌ساز گزارش می‌دهد)
- مجوزها و محدوده‌بندی عامل‌ها برای جلوگیری از اقدامات غیرمجاز

۴.۳ SDK/API عامل

- API عمومی برای توسعه عامل‌های شخص ثالث
- فرآیند ارسال و بررسی عامل در بازار
- جعبه شنی و ایزوله‌سازی امنیتی عامل‌ها

۵. نقشه راه مدیریت پروژه

۵.۱ ویژگی‌های پیشرفته وظایف

- ردیابی زمان وظایف با گزارش‌دهی
- وابستگی‌ها و موانع وظایف
- وظایف تکراری با زمان‌بندی قابل تنظیم
- قالب‌های وظیفه برای جریان‌های کاری رایج
- برنامه‌ریزی Sprint با ردیابی سرعت

۵.۲ گزارش‌دهی و تحلیل

- داشبوردهای بهره‌وری تیم
- گزارش پیشرفت پروژه با نقاط عطف
- نمودارهای تخصیص زمان بین پروژه‌ها
- نمودارهای Burndown برای ردیابی Sprint

۶. ریسک‌های امنیتی و DevOps — بخش بحرانی

۶.۱ ریسک‌های امنیتی فعلی

- بدون رمزنگاری سرتاسری — پیام‌ها به صورت متن ساده در پایگاه داده ذخیره می‌شوند
- توکن‌های JWT در localStorage ذخیره می‌شوند (آسیب‌پذیر در برابر حملات XSS)
- بدون محدودیت نرخ در نقاط پایانی API (خطر حمله انکار سرویس)
- هیچ بازرسی پاکسازی ورودی انجام نشده
- PIN قفل چت در فضای ذخیره‌سازی سمت کلاینت ذخیره می‌شود (وب: localStorage, موبایل: SecureStore)
- هدرهای Content Security Policy (CSP) پی‌گیری نشده
- بازرسی SQL injection انجام نشده (Prisma حفاظت نسبی ارائه می‌دهد اما کامل نیست)
- بازرسی XSS روی محتوای تولید شده توسط کاربر انجام نشده
- اعتبارنامه‌های WebRTC TURN ممکن است به صورت ثابت در کد موجود باشند

۶.۲ بهبودهای DevOps مورد نیاز

- خط لوله CI/CD (در حال حاضر git push دستی + بازسازی Docker)
- تست خودکار (صفر تست واحد، صفر تست یکپارچه‌سازی، صفر تست E2E)
- محیط Staging (در حال حاضر فقط محیط تولید)
- اتوماسیون پشتیبان‌گیری پایگاه داده
- تجمیع لاگ و مانیتورینگ (بدون ELK/Grafana/غیره)
- نقاط پایانی Health Check
- ارکستراسیون کانتینر (پیشنهاد Kubernetes برای مقیاس‌پذیری)
- CDN برای دارایی‌های استاتیک
- بازیابی Connection Pooling پایگاه داده
- کلاستر Redis برای دسترسی بالا

۶.۳ نگرانی‌های کیفیت کد

- برخی خطاهای TypeScript با تبدیل 'as any' سرکوب شده‌اند
- خطاهای از پیش موجود TypeScript در اپلیکیشن موبایل (ماژول ThemeContext گم‌شده و غیره)
- پی‌گیری Linting اعمال نشده
- فرآیند بررسی کد تعیین نشده
- فایل‌های کامپوننت بزرگ (برخی بیش از ۱۰۰۰ خط، باید تقسیم شوند)
- الگوهای مدیریت خطای ناسازگار در سراسر کد

۶.۴ انطباق و مسائل حقوقی

- انطباق GDPR تأیید نشده
- سیاست‌های نگهداری داده پیاده‌سازی نشده
- صادرات داده کاربر (حق قابلیت حمل) پیاده‌سازی نشده
- حذف حساب (حق پاک‌سازی) کاملاً تأیید نشده
- محتوای سیاست حریم خصوصی نیاز به بررسی حقوقی دارد
- مدیریت رضایت کوکی پیاده‌سازی نشده

۶.۵ اقدامات اولویت‌دار توصیه شده

1. **فوری:** اضافه کردن محدودیت نرخ و پاک‌سازی ورودی
2. **فوری:** راه‌اندازی پشتیبان‌گیری خودکار پایگاه داده
3. **هفته ۱:** پیاده‌سازی خط لوله CI/CD با تست خودکار
4. **هفته ۲:** اضافه کردن هدرهای CSP و هدرهای امنیتی
5. **هفته ۳:** چرخش توکن JWT و ذخیره‌سازی امن
6. **ماه ۱:** شروع پیاده‌سازی E2EE
7. **ماه ۱:** راه‌اندازی مانیتورینگ و هشداردهی
8. **ماه ۲:** تکمیل بازرسی امنیتی با تست نفوذ